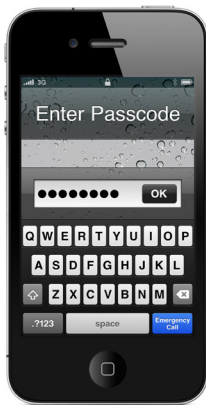




iPhone in Business

Security Overview



Device protection

- Strong passcodes
- Passcode expiration
- Passcode reuse history
- Maximum failed attempts
- Over-the-air passcode enforcement
- Progressive passcode timeout

Data security

- Remote wipe
- Local wipe
- Encrypted configuration profiles
- Encrypted iTunes backups
- Hardware encryption
- Data protection

Network security

- Built-in Cisco IPSec, L2TP, PPTP VPN
- SSL VPN via App Store apps
- SSL/TLS with X.509 certificates
- WPA/WPA2 Enterprise with 802.1x
- Certificate-based authentication
- RSA SecurID, CRYPTOCARD

Platform security

- Runtime protection
- Mandatory code signing
- Keychain services
- Common Crypto APIs
- Application data protection

iPhone can securely access corporate services and protect data on the device. iPhone provides strong encryption for data in transmission, proven authentication methods for access to corporate services, and hardware encryption for all data stored on the device. iPhone also provides secure protection through the use of passcode policies that can be delivered and enforced over the air. And if the device falls into the wrong hands, users and IT administrators can initiate a remote wipe command to erase private information.

When considering the security of iPhone for enterprise use, it's helpful to understand the following:

- **Device Security:** Methods that prevent unauthorized use of the device
- **Data Security:** Protecting data at rest, even when a device is lost or stolen
- **Network Security:** Networking protocols and the encryption of data in transmission
- **Application Security:** The secure platform foundation of iOS

These capabilities work in concert to provide a secure mobile computing platform.

Device Security

Establishing strong policies for access to iPhone is critical to protecting corporate information. Device passcodes are the front line of defense against unauthorized access and can be configured and enforced over the air. iPhone uses the unique passcode established by each user to generate a strong encryption key to further protect mail and sensitive application data on the device. Additionally, iPhone provides secure methods to configure the device in an enterprise environment where specific settings, policies, and restrictions must be in place. These methods provide flexible options for establishing a standard level of protection for authorized users.

Passcode Policies

A device passcode prevents unauthorized users from accessing data stored on iPhone or otherwise gaining access to the device. iOS 4 allows you to select from an extensive set of passcode requirements to meet your security needs, including timeout periods, passcode strength, and how often the passcode must be changed.

The following passcode policies are supported:

- Require passcode on device
- Allow simple value
- Require alphanumeric value
- Minimum passcode length
- Minimum number of complex characters
- Maximum passcode age
- Auto-lock
- Passcode history

- Grace period for device lock
- Maximum number of failed attempts

Policy Enforcement

The policies described above can be set on iPhone in a number of ways. Policies can be distributed as part of a configuration profile for users to install. A profile can be defined so that deleting the profile is only possible with an administrative password, or you can define the profile so that it is locked to the device and cannot be removed without completely erasing all of the device contents. Additionally, passcode settings can be configured remotely using Mobile Device Management solutions that can push policies directly to the device. This enables policies to be enforced and updated without any action by the user.

Alternatively, if the device is configured to access a Microsoft Exchange account, Exchange ActiveSync policies are pushed to the device over the air. Keep in mind that the available set of policies will vary depending on the version of Exchange (2003, 2007, or 2010). Refer to the Enterprise Deployment Guide for a breakdown of what policies are supported for your specific configuration.

Secure Device Configuration

Configuration profiles are XML files that contain device security policies and restrictions, VPN configuration information, Wi-Fi settings, email and calendar accounts, and authentication credentials that permit iPhone to work with your enterprise systems. The ability to establish passcode policies along with device settings in a configuration profile ensures that devices within your enterprise are configured correctly and according to security standards set by your organization. And because configuration profiles can be encrypted and locked, the settings cannot be removed, altered, or shared with others.

Configuration profiles can be both signed and encrypted. Signing a configuration profile ensures that the settings it enforces cannot be altered in any way. Encrypting a configuration profile protects the profile's contents and permits installation only on the device for which it was created. Configuration profiles are encrypted using CMS (Cryptographic Message Syntax, RFC 3852), supporting 3DES and AES 128.

The first time you distribute an encrypted configuration profile, you install them via USB sync using the iPhone Configuration Utility or wirelessly via Over-the-Air Enrollment. In addition to these methods, subsequent distribution of encrypted configuration profiles can be delivered via email attachment, hosted on a website accessible to your users, or pushed to the device using Mobile Device Management solutions.



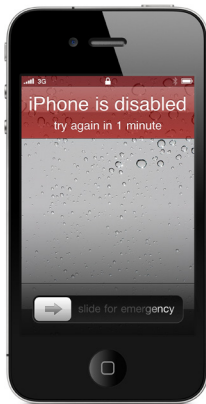
Available restrictions

- Access to iTunes Music Store
- Access to explicit media and content ratings in iTunes Store
- Use of Safari and security preferences
- Use of YouTube
- Use of App Store and in-app purchase
- Installing apps
- Ability to screen capture
- Automatic sync while roaming
- Use of voice dialing
- Enforce encrypted iTunes backups
- Use of the camera

Device Restrictions

Device restrictions determine which iPhone features your users can access on the device. Typically, these involve network-enabled applications such as Safari, YouTube, or the iTunes Store, but restrictions can also control device functionality such as application installation, or use of the camera. Device restrictions let you configure the device to meet your requirements, while permitting users to utilize the device in ways that are consistent with your business practices. Restrictions can be manually configured on each device, enforced using a configuration profile, or established remotely with Mobile Device Management solutions. Additionally, camera and web-browsing restrictions can be enforced over the air via Microsoft Exchange Server 2007 and 2010.

In addition to setting restrictions and policies on the device, the iTunes desktop application can be configured and controlled by IT. This includes disabling access to explicit content, defining which network services users can access within iTunes, and whether new software updates are available for them to install.



Progressive passcode timeout

iPhone can be configured to automatically initiate a wipe after several failed passcode attempts. If a user repeatedly enters the wrong passcode, iPhone will be disabled for increasingly longer intervals. After too many unsuccessful attempts, all data and settings on the device will be erased.

Data Security

Protecting data stored on iPhone is important for any environment with a high level of sensitive corporate or customer information. In addition to encrypting data in transmission, iPhone provides hardware encryption for data stored on the device, and additional encryption of email and application data with enhanced data protection.

If a device is lost or stolen, it's important to deactivate and erase the device. It's also a good idea to have a policy in place that will wipe the device after a defined number of failed passcode attempts, a key deterrent against attempts to gain unauthorized access to the device.

Encryption

iPhone 3GS and new devices offer hardware-based encryption. iPhone hardware encryption uses AES 256-bit encoding to protect all data on the device. Encryption is always enabled, and cannot be disabled by users.

Additionally, data backed up in iTunes to a user's computer can be encrypted. This can be enabled by the user, or enforced by using device restriction settings in configuration profiles.

Data Protection

Building on the hardware encryption capabilities of iPhone 3GS and newer devices, email messages and attachments stored on the device can be further secured by using data protection features built into iOS 4. Data protection leverages each user's unique device passcode in concert with the hardware encryption on iPhone to generate a strong encryption key. This key prevents data from being accessed when the device is locked, ensuring that critical information is secured even if the device is compromised.

Enabling data protection requires that existing devices be fully restored from backup when upgrading to iOS 4. New devices that ship with iOS 4 will already have this capability. To turn on the data protection feature, simply establish a passcode on the device. The effectiveness of data protection is dependent on a strong passcode, so it is important to require and enforce a passcode stronger than four digits when establishing your corporate passcode policies. Users can verify that data protection is enabled on their device by looking at the passcode settings screen. Mobile Device Management solutions are able to query the device for this information as well.

These data protection APIs are also available to developers, and can be used to secure enterprise in-house or commercial application data.

Remote Wipe

iPhone supports remote wipe. If a device is lost or stolen, the administrator or device owner can issue a remote wipe command that removes all data and deactivates the device. If the device is configured with an Exchange account, the administrator can initiate a remote wipe command using the Exchange Management Console (Exchange Server 2007) or Exchange ActiveSync Mobile Administration Web Tool (Exchange Server 2003 or 2007). Users of Exchange Server 2007 can also initiate remote wipe commands directly using Outlook Web Access. Remote wipe commands can also be initiated by Mobile Device Management solutions even if Exchange corporate services are not in use.

Local Wipe

Devices can also be configured to automatically initiate a local wipe after several failed passcode attempts. This protects against brute force attempts to gain access to the device. When a passcode is established, users have the ability to enable local wipe directly within the settings on iPhone. By default, iPhone will automatically wipe the device after 10 failed passcode attempts. As with other passcode policies, the maximum number of failed attempts can be established via a configuration profile, set by a Mobile Device Management server, or enforced over the air via Microsoft Exchange ActiveSync policies.



VPN protocols

- Cisco IPSec
- L2TP/IPSec
- PPTP
- SSL VPN

Authentication methods

- Password (MSCHAPv2)
- RSA SecurID
- CRYPTOCARD
- x.509 Digital Certificates
- Shared secret

802.1x authentication protocols

- EAP-TLS
- EAP-TTLS
- EAP-FAST
- EAP-SIM
- PEAP v0, v1
- LEAP

Supported certificate formats

iPhone supports X.509 certificates with RSA keys. The file extensions .cer, .crt, and .der are recognized.

Network Security

Mobile users must be able to access corporate information networks from anywhere in the world, yet it's also important to ensure that users are authorized and that their data is protected during transmission. iPhone provides proven technologies to accomplish these security objectives for both Wi-Fi and cellular data network connections.

VPN

Many enterprise environments have some form of virtual private networking established. These secure network services are already deployed and typically require minimal setup and configuration to work with iPhone.

Out of the box, iPhone integrates with a broad range of commonly used VPN technologies through support for Cisco IPSec, L2TP, and PPTP. Additionally, iPhone supports SSL VPN through applications from Juniper and Cisco. Support for these protocols ensures the highest level of IP-based encryption for transmission of sensitive information.

In addition to enabling secure access to existing VPN environments, iPhone offers proven methods for user authentication. Authentication via standard x.509 digital certificates provides users with streamlined access to company resources and a viable alternative to using hardware-based tokens. Additionally, certificate authentication enables iPhone to take advantage of VPN On Demand, making the VPN authentication process transparent while still providing strong, credentialed access to network services. For enterprise environments in which a two-factor token is a requirement, iPhone integrates with RSA SecurID and CRYPTOCARD.

iPhone supports network proxy configuration as well as split IP tunneling so that traffic to public or private network domains is relayed according to your specific company policies.

SSL/TLS

iPhone supports SSL v3 as well as Transport Layer Security (TLS v1.0), the next-generation security standard for the Internet. Safari, Calendar, Mail, and other Internet applications automatically start these mechanisms to enable an encrypted communication channel between iPhone and corporate services.

WPA/WPA2

iPhone supports WPA2 Enterprise to provide authenticated access to your enterprise wireless network. WPA2 Enterprise uses 128-bit AES encryption, giving users the highest level of assurance that their data will remain protected when they send and receive communications over a Wi-Fi network connection. And with support for 802.1x, iPhone can be integrated into a broad range of RADIUS authentication environments.

Application Security

iOS is designed with security at its core. It includes a "sandboxed" approach to application runtime protection and requires application signing to ensure that applications cannot be tampered with. iOS also has a secure framework that facilitates secure storage of application and network service credentials in an encrypted keychain. For developers, it offers a common crypto architecture that can be used to encrypt application data stores.

Runtime Protection

Applications on the device are "sandboxed" so they cannot access data stored by other applications. In addition, system files, resources, and the kernel are shielded from the user's application space. If an application needs to access data from another application, it can only do so using the APIs and services provided by iOS. Code generation is also prevented.

Mandatory Code Signing

All iPhone applications must be signed. The applications provided with the device are signed by Apple. Third-party applications are signed by the developer using an Apple-issued certificate. This ensures that applications haven't been tampered with or altered. Additionally, runtime checks are made to ensure that an application hasn't become untrusted since it was last used.

The use of custom or in-house applications can be controlled with a provisioning profile. Users must have the provisioning profile installed to execute the application. Provisioning profiles can be installed or revoked over the air using Mobile Device Management solutions. Administrators can also restrict the use of an application to specific devices.

Secure Authentication Framework

iPhone provides a secure, encrypted keychain for storing digital identities, user names, and passwords. Keychain data is partitioned so that credentials stored by third-party applications cannot be accessed by applications with a different identity. This provides the mechanism for securing authentication credentials on iPhone across a range of applications and services within the enterprise.

Common Crypto Architecture

Application developers have access to encryption APIs that they can use to further protect their application data. Data can be symmetrically encrypted using proven methods such as AES, RC4, or 3DES. In addition, iPhone provides hardware acceleration for AES encryption and SHA1 hashing, maximizing application performance.

Application Data Protection

Applications can also take advantage of the built-in hardware encryption on iPhone to further protect sensitive application data. Developers can designate specific files for data protection, instructing the system to make the contents of the file cryptographically inaccessible to both the application and to any potential intruders when the device is locked.

Revolutionary Phone, Secure Throughout

iPhone provides encrypted protection of data in transit, at rest, and when backed up to iTunes. Whether a user is accessing corporate email, visiting a private website, or authenticating to the corporate network, iPhone provides assurance that only authorized users can access sensitive corporate information. And, with its support for enterprise-grade networking and comprehensive methods to prevent data loss, you can deploy iPhone with confidence that you are implementing proven mobile device security and data protection.

For additional information and deployment resources for iPhone visit:
www.apple.com/iphone/business/integration/